Phase 1 – SharePoint Secure File Access Solution Zero Touch + Zero Trust Architecture

Company Size: 300 Users

---

1 Solution Overview

This solution delivers secure, centralized file storage using **SharePoint Online** with:

- Zero Touch device provisioning
- Zero Trust access enforcement
- Device-based Conditional Access controls

The architecture ensures that corporate data is accessible **only from trusted, company-managed, compliant devices**.

The solution leverages:

- Microsoft 365 E5
- Microsoft Entra ID P1
- Microsoft Intune
- Windows Autopilot
- Conditional Access
- Microsoft Defender for Cloud Apps

Security Design Principles

This architecture follows Microsoft Zero Trust principles:

✓ Verify explicitly (MFA + Passwordless + identity validation)

✓ Use least privilege access

✓ Assume breach

✓ Enforce device trust before data access

Access to SharePoint is restricted to:

Licensed users only

Company-owned devices only

Entra ID–joined devices only

Intune-compliant devices only

Strongly-authenticated users only

Unmanaged, personal, or non-compliant devices are blocked automatically.

---

2 Architecture Design (High-Level)

Identity Layer

- Microsoft Entra ID (Authentication + Device Identity)
- Multi-Factor Authentication (MFA)
- Passwordless Authentication (Windows Hello for Business + FIDO2)
- Device identity validation

Device Provisioning Layer

- Windows Autopilot (Zero Touch provisioning)

Device Management Layer

- Microsoft Intune (Compliance + Security Baselines + Endpoint Configuration)

Access Control Layer

- Conditional Access Policies
  - MFA enforcement
  - Require compliant device
  - Require Entra ID joined device
  - Block legacy authentication
  - Admin protection policies

Data Layer

- SharePoint Online (Single Team Site)

Protection Layer

- Defender for Cloud Apps
- BitLocker encryption
- Microsoft 365 Backup
- Defender for Business (EDR)

---

3 Windows Autopilot – Zero Touch Provisioning Model

Objective

Provision new laptops without IT manual setup.

Device Enrollment Flow

1. Laptop purchased from OEM (Dell/HP/Lenovo) with Autopilot registration
2. Device hardware hash uploaded to tenant

3. Autopilot deployment profile assigned
4. User receives sealed laptop
5. User powers on device and connects to internet
6. User signs in using corporate email
7. Strong authentication completed (MFA or Passwordless – Windows Hello for Business / FIDO2)
8. Device automatically:
    - Joins Microsoft Entra ID
    - Enrolls in Intune
    - Applies security baseline
    - Applies compliance policies
9. Device marked compliant
10. Conditional Access grants SharePoint access

No IT login required or manual configuration required..

---

4 Autopilot Deployment Profile Configuration

Profile Type:

User-Driven Microsoft Entra ID Join

Configured Settings:

- Join to Microsoft Entra ID
- Automatically enroll in Intune
- Standard user (no local admin)
- Hide privacy settings
- Hide EULA
- Require MFA during setup
- Assign device ownership = Company

This ensures Zero Touch and Zero Admin device provisioning.

---

5 Device Compliance & Security Baseline (Intune)

All Autopilot devices automatically receive:

Compliance Policies

- BitLocker enabled
- Antivirus enabled
- Firewall enabled
- OS up-to-date
- Password / PIN enforced
- Secure Boot required

Security Baseline

- Defender Antivirus policy
- Attack Surface Reduction rules
- Credential theft protection
- Ransomware behavior blocking
- Endpoint firewall rules

If a device becomes non-compliant:
→ Conditional Access automatically blocks SharePoint access.

---

6 Conditional Access Design

1. Baseline MFA Policy

- Applies to all cloud apps
- Requires MFA
- Passwordless authentication enabled
- Legacy authentication blocked
- Excludes emergency break-glass accounts

2. SharePoint Access Policy

Requires:

- Licensed user
- MFA or passwordless authentication completed
- Device is Entra ID joined
- Device is marked compliant in Intune
- Device ownership = Company

Blocks:

- Personal laptops

- BYOD devices
- Unmanaged browsers
- Non-compliant devices

3. Legacy Authentication Block Policy

- Blocks IMAP, POP, SMTP AUTH

4. Admin Protection Policy

- Requires phishing-resistant authentication
- FIDO2 security keys for privileged roles
- Requires compliant device
- Applies to privileged roles
- Time-bound access via Microsoft Entra ID Privileged Identity Management (PIM)

---

7 SharePoint Online Configuration

Purpose:
Centralized secure document storage.

Design:

- Single Team Site
- External sharing disabled by default
- Named guest access only (controlled exceptions)
- Audit logging enabled
- Version history enabled

Access is enforced through Entra ID + Conditional Access.

---

8 OneDrive + SharePoint Auto-Mapping (Zero IT Effort)

Instead of manual shortcut setup:

Intune policy is configured to:

- Silently sign in users to OneDrive
- Automatically sync SharePoint document library

Result:

Users access SharePoint from:

This PC → Company Name (OneDrive)

No manual configuration required.

If device becomes non-compliant:
→ Sync automatically stops.

---

9 Mobile Device Policy

Default:

- SharePoint access blocked from mobile devices

Optional Business Exception:
Allow access via:

- Outlook Mobile
- OneDrive Mobile

Enforced with:

- App Protection Policies
- PIN required
- No local storage
- No copy/paste to personal apps

---

10 Backup & Data Protection

Microsoft 365 Backup **separate add-on service** protects:

- SharePoint Online
- OneDrive
- Exchange Online

Protects against:

- Accidental deletion
- Ransomware
- Insider threats

Backup storage is isolated and encrypted.

---

11 Emergency Access (Break-Glass Accounts)

- Two cloud-only Global Admin accounts
- Strong passwords stored offline
- Excluded from Conditional Access

- Used only during emergency scenarios

Prevents tenant lockout.

---

12 End-to-End Zero Trust Access Flow

1. Device powered on
2. Autopilot profile detected
3. User signs in using passwordless authentication (Windows Hello / FIDO2) or MFA
4. Authentication validated by Microsoft Entra ID
5. Device joins Entra ID
6. Device enrolls in Intune
7. Compliance evaluated
8. Conditional Access evaluated
9. SharePoint access granted only if:
    - User authenticated
    - Strong authentication passed
    - Device compliant
    - Device company-owned

---

13 Privileged Access Management (PIM – Just-In-Time Admin Control)

To eliminate permanent privileged access and reduce lateral movement risk, the architecture includes:

Using Microsoft Entra ID Privileged Identity Management (PIM):

Controls Implemented

• No permanent Global Admin assignments
• Just-In-Time (JIT) role activation
• Time-bound privileged access (1–4 hours max)
• Approval-based activation for critical roles
• MFA required during activation
• Full audit trail of privileged activities

Benefits

✓ Reduces standing admin exposure
✓ Minimizes insider threat risk
✓ Enhances audit & compliance posture

---

14 Data Loss Prevention (DLP) & Information Protection

To prevent sensitive data leakage from Microsoft SharePoint Online and OneDrive:

DLP Policies Configured

• Financial data protection
• PAN / Aadhaar detection (India compliance)
• HR & payroll document protection
• Confidential project files

Sensitivity Labels

• Public
• Internal
• Confidential
• Highly Confidential

Labels enforce:
• Encryption
• Access restrictions
• Download limitations
• Watermarking (optional)

Auto-Labeling (Optional Advanced)

Automatic classification based on sensitive content patterns.

✓ Prevents accidental sharing
✓ Prevents external data leakage
✓ Strengthens compliance readiness

---

15 Advanced Threat & Email Protection

Email security enhancements using Microsoft 365 security capabilities:

Protection Controls

• Anti-phishing impersonation protection
• Safe Links (malicious URL scanning)
• Safe Attachments (sandbox detonation)
• External sender tagging
• Quarantine policy enforcement

✓ Reduces ransomware entry points
✓ Protects executives from spoofing attacks

---

16 Endpoint Detection & Response (EDR)

Using **Microsoft Defender for Endpoint (Plan 2):**

• Real-time endpoint detection
• Behavioral threat monitoring
• EDR in block mode
• Automated investigation & remediation
• Ransomware rollback capability
• Centralized security dashboard

Integrated with:
• Microsoft Intune
• Conditional Access policies

✓ Rapid threat containment
✓ Reduced mean-time-to-remediation

---

17 Patch & Update Governance Strategy

To ensure controlled OS updates:

Windows Update Rings

• Pilot Group (IT devices) – Early validation
• Production Group – Staggered deployment
• Emergency Patch Ring – Critical vulnerabilities

Controls

• Automatic quality updates
• Feature update deferral strategy
• Forced compliance after grace period
• Reporting dashboard review

✓ Prevents mass update failures
✓ Ensures security patches applied timely
✓ Supports audit compliance

---

18 Business Continuity & Disaster Recovery (BCDR)

Defined operational resilience metrics:

Recovery Objectives

• RPO (Recovery Point Objective): 24 hours
• RTO (Recovery Time Objective): 4–8 hours

Backup Strategy

• Daily automated backup
• Backup storage isolated & encrypted
• Quarterly restore testing
• Retention policy defined

Protects against:
• Accidental deletion
• Ransomware
• Insider threat
• Service outage

---

19 Network & Geo Access Controls (Hardening)

Conditional Access enhancements:

• Named trusted locations
• Country-based access restrictions
• Geo-block high-risk countries
• Block TOR & anonymous proxy IPs

✓ Reduces international brute-force attempts
✓ Limits attack surface

---

20 Audit, Logging & Compliance Governance

Logging & retention configuration:

• Unified Audit Log enabled
• Log retention: no. of days (default) / extended if required
• Admin activity logging enabled
• Sign-in log monitoring automated
• Monthly compliance report review
• Legal Hold capability (if required for HR/Legal cases)

✓ Supports regulatory audits
✓ Improves forensic readiness

🔐 Security Controls Summary

Security Control	Technology
Identity	Microsoft Entra ID
Privileged Access	Entra ID PIM
MFA	Conditional Access
Passwordless Authentication	Windows Hello for Business + FIDO2
Device Provisioning	Windows Autopilot
Device Compliance	Microsoft Intune
Endpoint Security	Defender for Business (EDR)
File Storage	SharePoint Online
Data Protection	DLP + Sensitivity Labels

Security Control	Technology
CASB	Defender for Cloud Apps
Backup	Microsoft 365 Backup
Update Governance	Windows Update Rings
Logging	Unified Audit Logs

Why This Design Fits a 300-User Organization

✓ Zero Touch provisioning through Windows Autopilot
✓ No on-premises infrastructure required
✓ No VPN dependency
✓ Scalable architecture (300 → 3000+ users)
✓ Fully Zero Trust aligned
✓ Audit-ready configuration
✓ Standardized device deployment
✓ Reduced IT operational overhead
✓ Strong ransomware and endpoint protection

This design eliminates traditional infrastructure complexity while enforcing modern identity-driven security controls suitable for a growing organization.

Final Summary

Microsoft 365 E5 provides:

- SharePoint Online → Secure file storage
- Microsoft Entra ID P2 → Identity & Conditional Access
- Windows Autopilot → Zero Touch provisioning
- Microsoft Intune → Device compliance enforcement
- Defender for Cloud Apps → Data protection

This architecture ensures organizational data is accessible **only from trusted, compliant, company-owned devices** provisioned via Zero Touch onboarding and authenticated using strong identity controls.